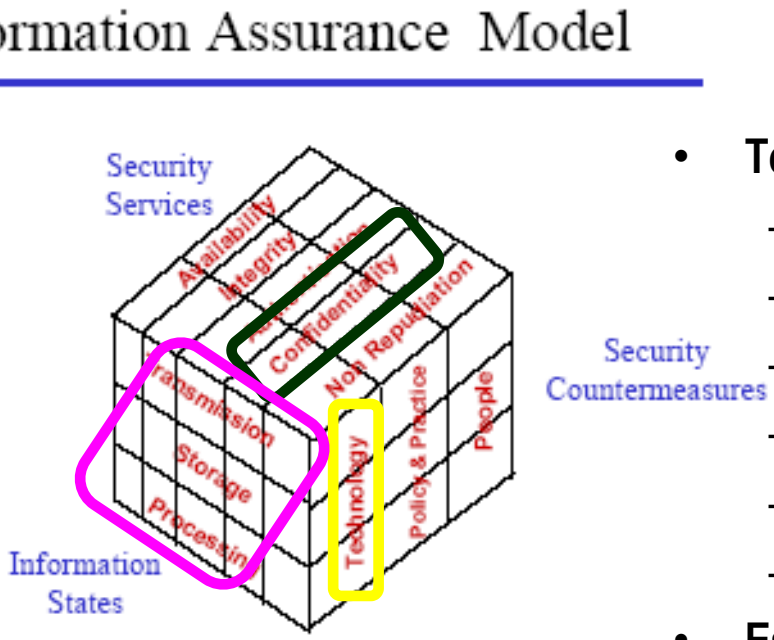
UNIVERSIDAD D SEVILLA

Tema 3. Confidencialidad de la Información (I)
Cifrado de Clave Simétrica y Asimétrica

Dr. Rafael Martínez Gasca
Grupo de Investigación **Quivir**,
Tecnologías Inteligentes y de Seguridad de los Sistemas de Información
Departamento de Lenguajes y Sistemas Informáticos
Universidad de Sevilla

Indice

- Introducción. Conceptos Fundamentales
- Implementación tecnológica de los requisitos



- Técnicas Criptográficas
  - Cifrado de clave simétrica
  - Cifrado de clave asimétrica
  - Protocolo de Acuerdo de Clave
  - Protocolo SSL/TLS,SSH, PGP y SRTP
  - Protocolo WEP, WAP y WAP2
  - XML Encryption
- Esteganografía

Implementación de la Confidencialidad

- Las estrellas en la confidencialidad con criptografía son:

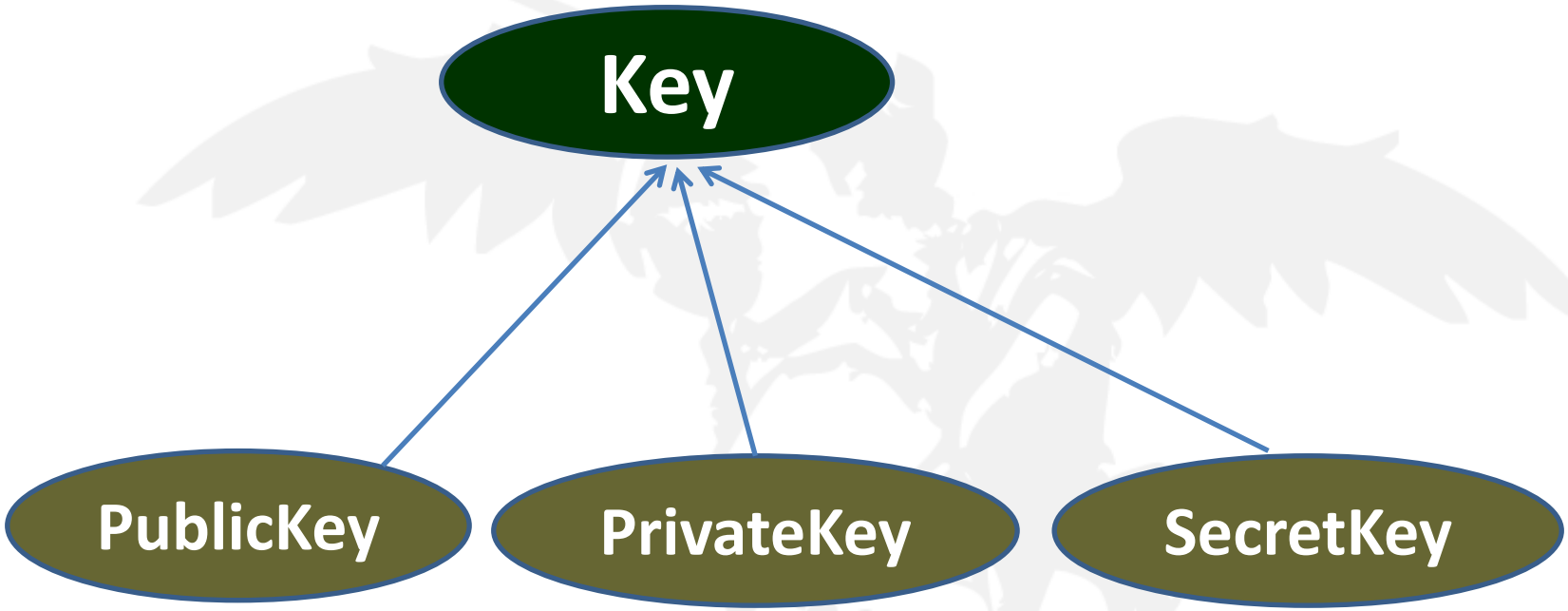


Implementación de la Confidencialidad

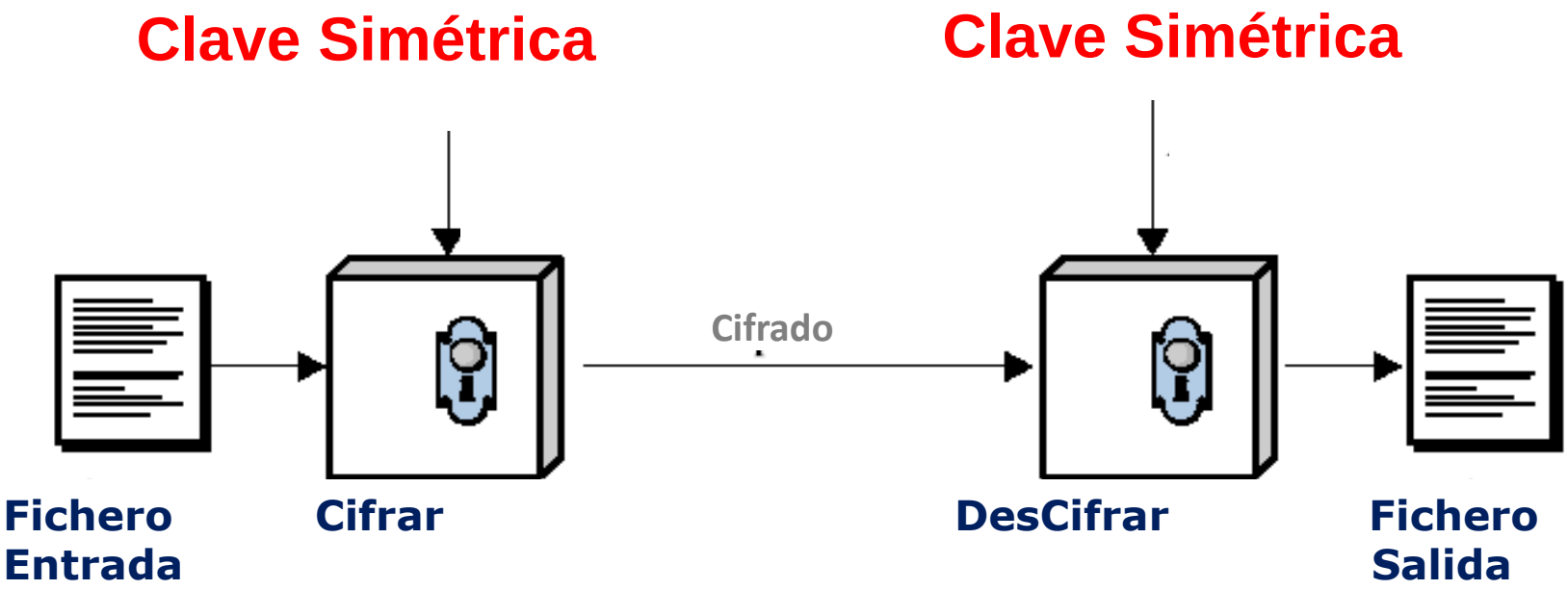
- **Criptografía (secret writing):** cifrar información de manera que sea ininteligible para usuarios no autorizados,
- **Esteganografía (covered writing).** Ocultar mensajes dentro de otros.
- **Híbrido:** Uso de criptografía y esteganografía

- Conceptos Fundamentales
- Implementación de los requisitos de confidencialidad
  - Criptografía
    - Cifrado de clave simétrica
    - Cifrado de clave asimétrica
    - Protocolo de Acuerdo de Clave
    - Protocolo SSL/TLS, SSH, PGP y SRTP
    - Protocolo WEP, WAP y WAP2
    - XML Encryption
  - Esteganografía

- Criptografía: En Java por ejemplo, las interfaces ***PublicKey, PrivateKey y SecretKey*** representan los distintos tipos de claves.



Algoritmos de clave secreta o simétricos



Implementación de la Confidencialidad.
Cifrado de clave Secreta

- Algoritmos de cifrado de **clave secreta o simétricos**
  - Sustitución sencilla de una letra por otra
    - Puede parecer robusta, pero es vulnerable por considerar **frecuencias de letras y patrones de palabras de los idiomas(ataques de diccionario)**
  - **DES** (Data Encryption Standard). Es el antiguo "estándar de cifrado de datos" de los años setenta
    - Su tamaño clave es demasiado corto para una seguridad adecuada (64 bits, pero 56 bits efectivos y 8 para paridad)
  - DESede (3DES). Conexión en cascada de tres instancias de DES (con claves distintas).
    - Es lento, DES fue diseñado para la implementación de hardware eficiente

Implementación de la Confidencialidad.
Cifrado de clave Secreta

- Blowfish Tiene mejor velocidad de cifrado y cifrado más robusto (claves desde los 32 bits hasta 448 bits). Propuesto por Bruce Schneier. Utiliza bloques de 64 bits.
- AES, Advanced Encryption Standard (AES), también conocido como ***Rijndael***
  - Sucesor de DES como algoritmo estándar de cifrado simétrico para las Organizaciones Federales Estadounidenses (y para casi todos los demás)
  - Acepta claves de 128, 192 o 256 bits
  - Utiliza bloques de 128 bits y es eficiente en software y hardware
  - Fue seleccionado a través de un concurso abierto que involucró a cientos de criptógrafos durante varios años

Implementación de la Confidencialidad.
Cifrado de clave Secreta

- **Tamaño de la clave:** Un ataque de fuerza bruta involucra verificar sistemáticamente todas las combinaciones de claves posibles

Key Size	Possible combinations	Time to Crack (depending computer syst.)
1-bit	2	
2-bit	4	
4-bit	16	
8-bit	256	39s
16-bit	65536	
32-bit	4.2×10^9	
56-bit (DES)	7.2×10^{16}	$1.0\ 10^{18}$ años
64-bit	1.8×10^{19}	
128-bit (AES)	3.4×10^{38}	$1.9^*\ 10^{37}$ años
192-bit (AES)	6.2×10^{57}	
256-bit (AES)	1.1×10^{77}	3.3^*10^{56} años

- **Cifradores de bloque / flujo**
  - Un cifrador de ***bloque*** procesa un bloque de texto plano cada vez, produciendo el correspondiente bloque de texto cifrado (ej: 64 ó 128 bits). Toma un bloque de texto claro como entrada y produce un bloque de igual tamaño de texto cifrado. El descifrado es similar.
  - Un cifrador de ***flujo*** procesa la entrada de forma continua (ej: un bit cada vez). Trabaja sobre dígitos individuales, uno después del otro.

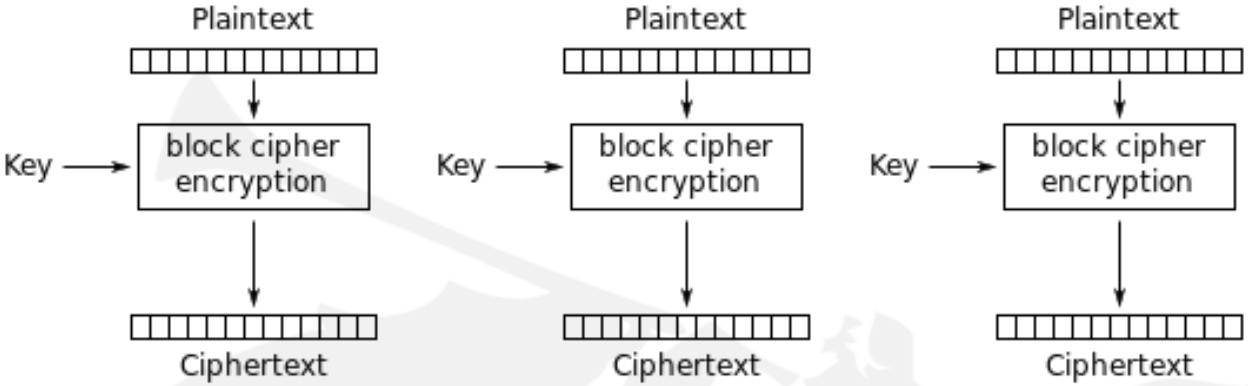
Implementación de la Confidencialidad.
Modos de operación

- Un cifrador de ***bloque*** procesa bloques de tamaño fijo
- Cuando se cifran mensajes más largos que el tamaño del bloque, el bloque cifrado puede estar o no influenciado por las aplicaciones del algoritmo a los bloques anteriores
- A estas distintas formas de influencia se les llama **modos de operación**
- Los modos de cifrado son: ECB, CBC, CFB, OFB, …

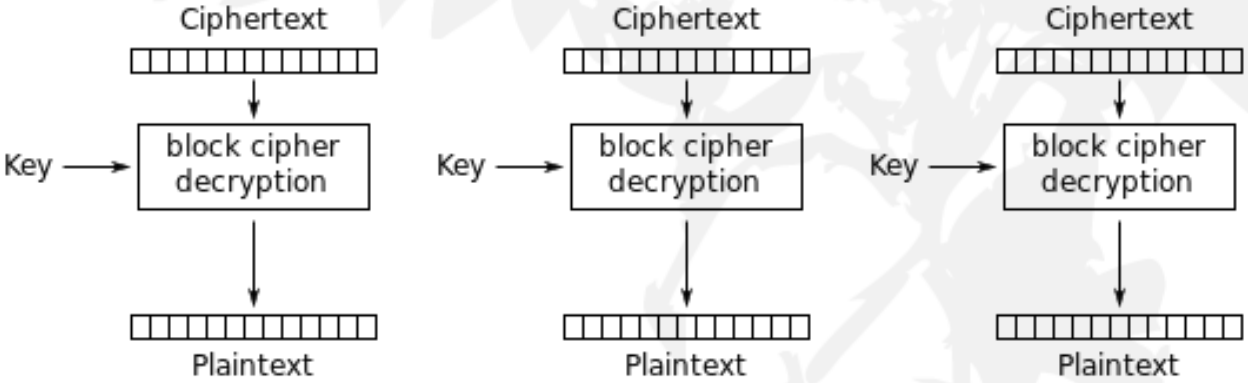
Implementación de la Confidencialidad.
Modos de operación

- **ECB** (**electronic codebook**). Cada uno de los bloques es cifrado por separado utilizando la misma clave. Útil ***para datos aleatorios***, tal como cifrar otras claves. Puesto que aquí los datos son cortos y aleatorios (sin patrones)
- **CBC** (**cipher block chaining**) especialmente útil ***para cifrar ficheros largos.***
  - Cada bloque de texto plano se le aplica la operación XOR con el bloque cifrado anterior antes de ser cifrado
  - Se usa un sistema de rellenado para conseguir que el texto en claro "rellenado" sea múltiplo del tamaño del bloque
- **CFB** (**cipher feedback**) es el mejor modo para cifrar ***streams de bytes (si hay ruido el stream se pude seguir sincronizando)***

Implementación de la Confidencialidad.
Modos de operación



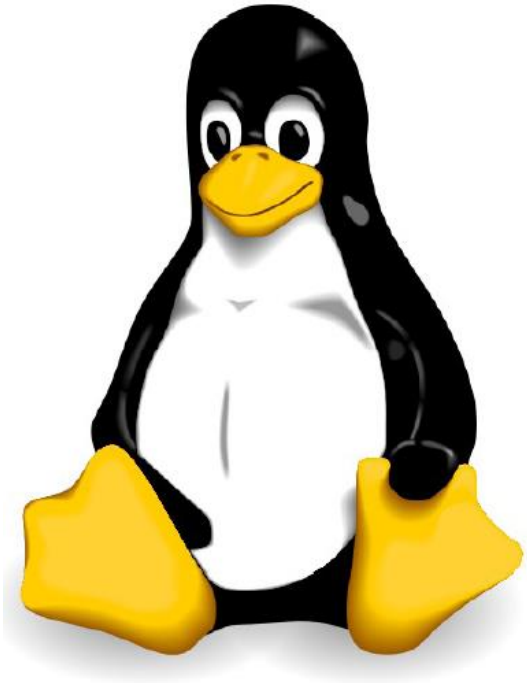
Electronic Codebook (ECB) mode encryption



Electronic Codebook (ECB) mode decryption

- Debilidades y Ventajas del modo ECB
  - **Debilidades: Repeticiones en los mensajes** (plaintext) pueden aparecen en el texto cifrado.
    - Particularmente con datos tales como gráficos
    - O con mensajes que cambian muy poco, el cual llega a ser un problema de análisis code-book
    - Esta debilidad es debida a que los bloques de mensajes cifrados son independientes
  - **Ventajas:** Por ello principal uso es para enviar pequeños bloques de datos y si son varios bloques que sean aleatorios.

- **Debilidades** con el modo ECB: Pueden quedar patrones del texto plano en el texto cifrado como en estas imágenes bitmap.



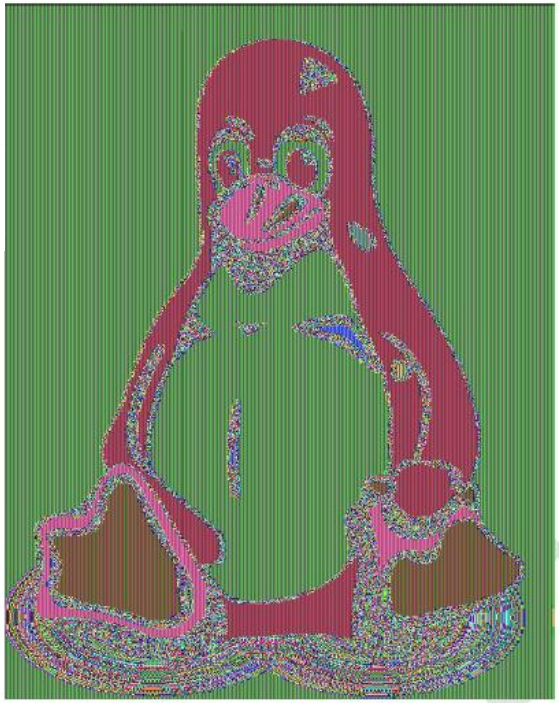
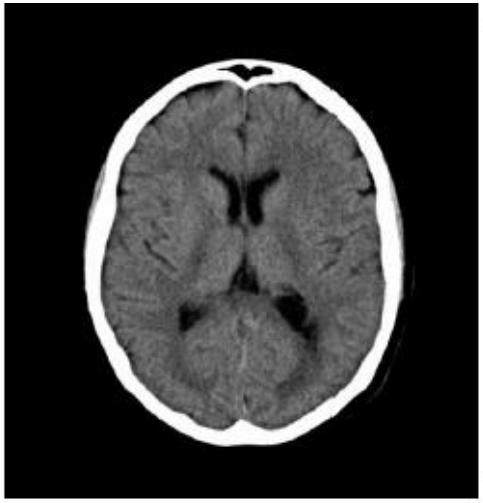
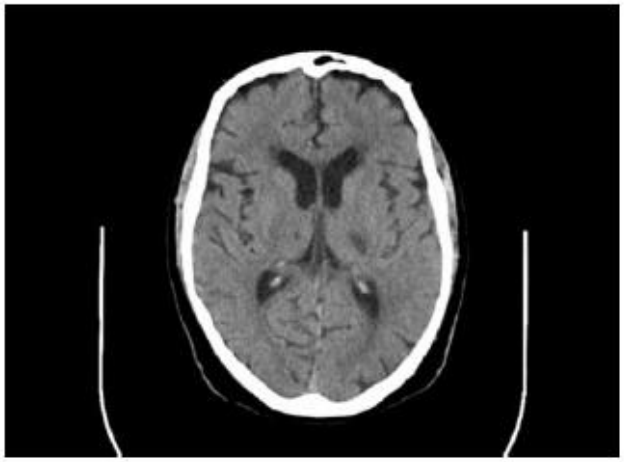


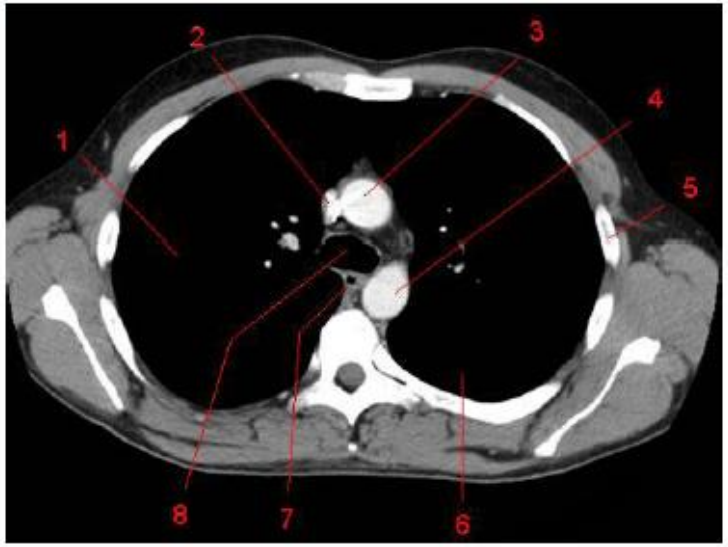
Imagen Original | Imagen Cifrada

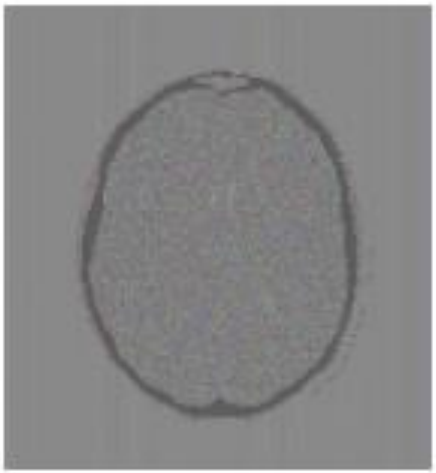
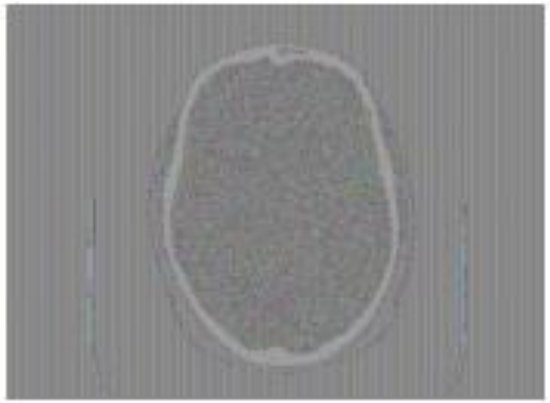




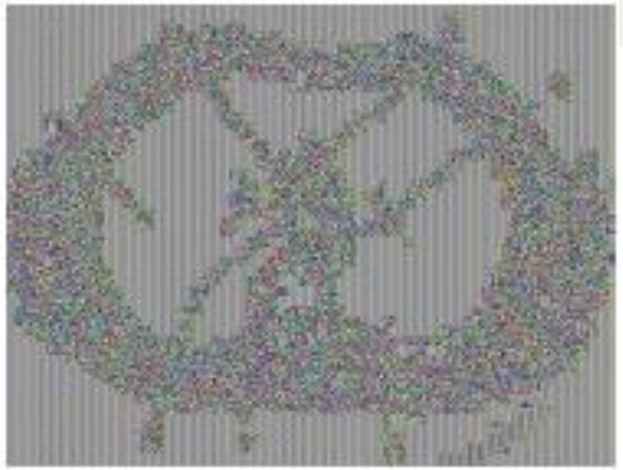


Imágenes a Cifrar (Plaintext)

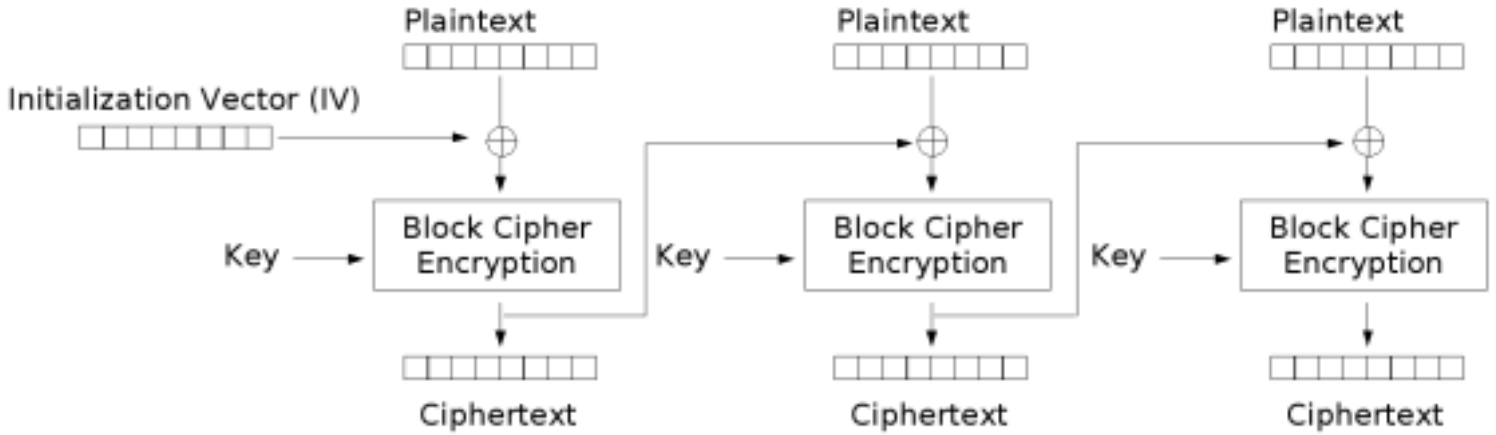


Imágenes Cifradas (Ciphertext)

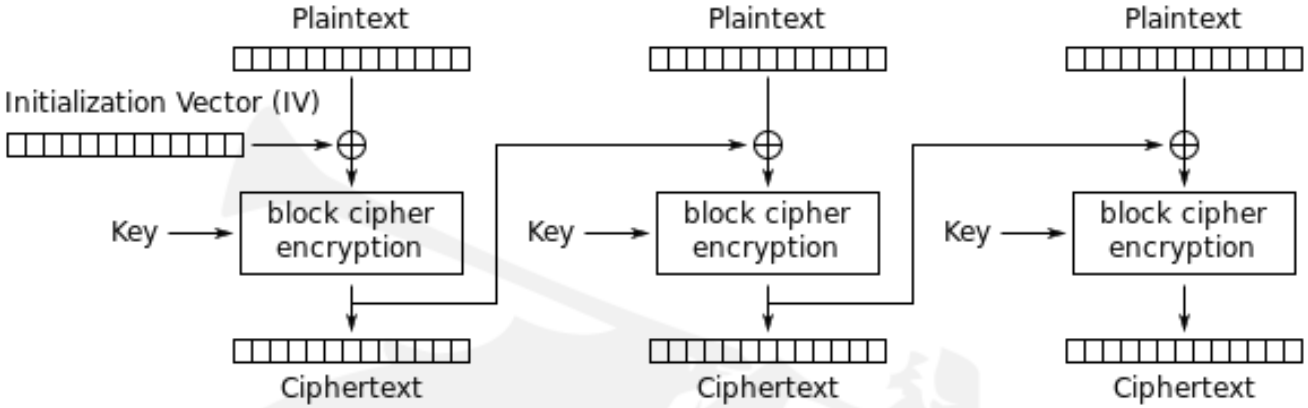


- **Modo CBC:** Para el cifrado, se divide a nivel binario el mensaje en *bloques de largo fijo*. Puede ser por ejemplo de 128 bits, pero depende del algoritmo. Se llama ***block cipher*** al algoritmo que dado un bloque de largo fijo y una clave, lo transforma en un bloque cifrado *(ciphertext)*.

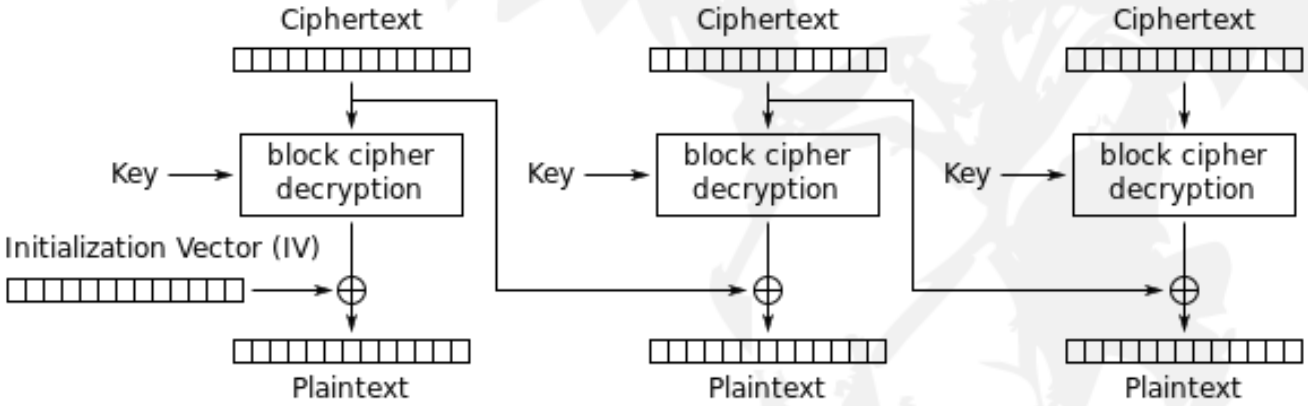


Cipher Block Chaining (CBC) mode encryption

Implementación de la Confidencialidad.
Modos de operación



Cipher Block Chaining (CBC) mode encryption

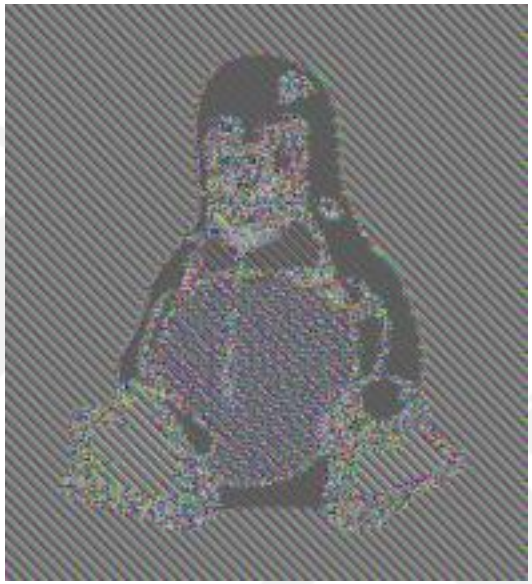


Cipher Block Chaining (CBC) mode decryption

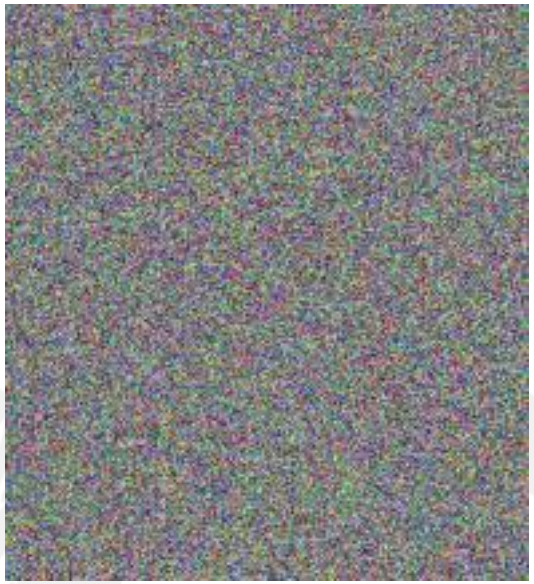
Implementación de la Confidencialidad.
Modos de operación



Original



Encrypted using ECB

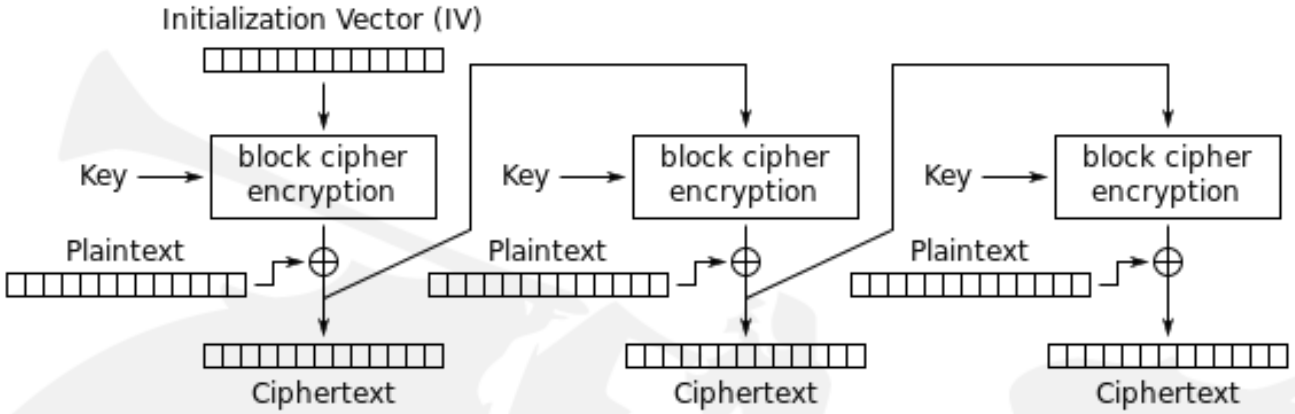


Encrypted using CBC

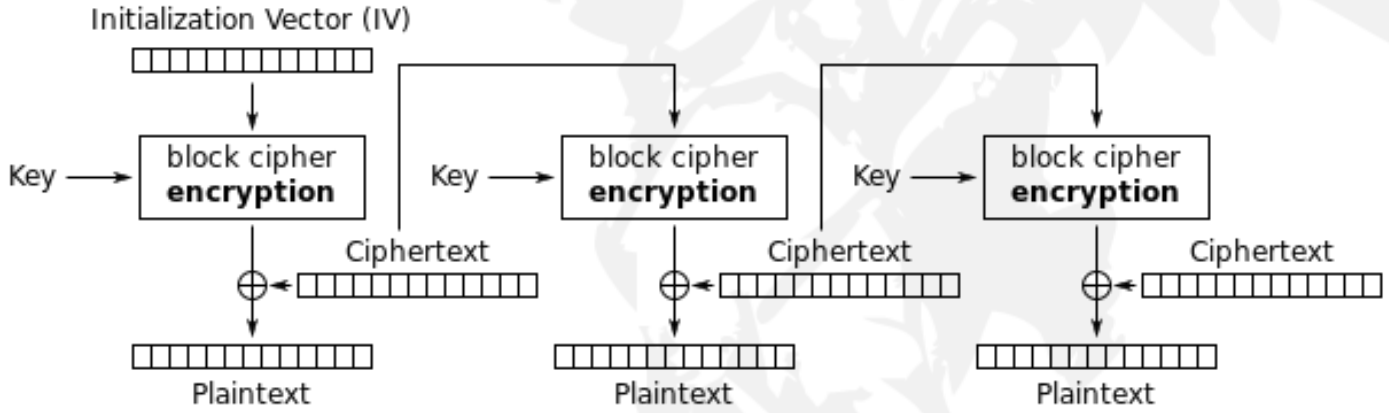
- **Ventajas e inconvenientes del modo CBC**
  - Cada bloque del ***ciphertext*** **depende de todos los bloques del** ***plaintext*** (efecto avalancha).
  - Necesita un **Initial Value** (IV) conocidos por emisor & receptor
    - Si IV se envia en claro un atacante puede cambiar los bits
    - Bien debe ser IV un valor fijo o debe enviarse cifrado en modo ECB antes de enviar el mensaje.
  - Cuando hay que cifrar menos bits que el tamaño del bloque (como los últimos bytes del mensaje), se añaden bytes adicionales para crear un buffer de entrada del tamaño del bloque. A esto se conoce como ***relleno*** (*padding*).
    - Se rellena bien con valores de non-data conocidos (ej: nulls)
    - O con un pad del último bloque con tamaño del pad (ejemplo [b1 b2 b3 0 0 0 0 **5**] serían 3 bytes de datos y 5 bytes a eliminar (pad+contador)
    - Para descifrar hay que diferenciar el mensaje original del mensaje de relleno

      estudiar padding !!! e tudo!
    - Los padding más usados son ***PKCS#5 y PKCS#7***

- Modo CFB



Cipher Feedback (CFB) mode encryption



Cipher Feedback (CFB) mode decryption

- **Cipher class**: Proporciona la funcionalidad de un cifrador criptográfico para el cifrado y el descifrado.
  - Se obtienen objetos ***Cipher*** con el método ***getInstance*** , y se pasa el nombre de la ***transformation*** requerida. Opcionalmente, se puede especificar el nombre de un ***Provider***.
  - Una ***transformation*** es una cadena que describe la operación (o conjunto de operaciones) a realizar dada una entrada, para producir alguna salida.
    - Incluye el nombre de un algoritmo criptográfico (e.g., *DES*), y puede seguirle un ***feedback mode*** y un ***padding scheme***.
    - Una transformación es de la forma "*algorithm/mode/padding*"

Cipher c =Cipher.getInstance("DES/CBC/PKCS5Padding");

Implementación de la Confidencialidad.
Cifrar Ficheros en Java

- Generar la clave secreta
  - ***keygen= KeyGenerator.getInstance("DESede");***
  - ***key=keygen.generateKey();***
- Graba la clave en un fichero DESClave.ser
  - ***fichclave= new ObjectOutputStream(new FileOutputStream(DESClave.ser)***
  - ***fichclave.writeObject(key); fichclave.close();***
- Crear un objeto cifrador con
  - ***codigo=Cipher.getInstance("DESede/ECB/PKCS5Padding");***
  - ***codigo.init(Cipher.ENCRYPT_MODE,key);***
- Construcción de objetos de lectura y escritura
  - ***entrada=BufferedInputStream(new FileInputStream("archivosincifrar"));***
  - ***salida=new CipherOutputStream(new BufferedOutputStream(new FileOutputStream("archivosalida")),codigo);***
- Cifrado:
  - Leer de entrada con ***read***
  - Escribir en salida con ***write***

Implementación de la Confidencialidad.
Descifrar Ficheros en Java

- Leer la clave
- Crear un objeto descifrador con
  - ***cifra=Cipher.getInstance("DESede/ECB/PKCS5Padding");***
  - ***cifra.init(Cipher.DECRYPT_MODE,key);***
- Construcción de objetos de lectura y escritura
  - ***entrada=CipherInputStream(new BufferedInputStream(new FileInputStream("archivocifrado")),cifra);***
  - ***salida=new BufferedOutputStream(new FileOutputStream ("archivosalida"));***
- Cifrado:
  - Leer de entrada con ***read***
  - Escribir en salida con ***write***
- Se puede hacer lo mismo pero con *Blowfish, AES* donde dice *DES* cambiar por *Blowfish o AES*

Implementación de la Confidencialidad.
Objetos Serializables en Java

- Dado un objeto que implementa la interfaz ***java.io.Serializable,*** puede crearse ***SealedObject***

```
Cipher c = Cipher.getInstance("AES");
c.init(Cipher.ENCRYPT_MODE, sKey); // para cifrarlo
SealedObject so = new SealedObject((Serializable) source, c);
```

- Para recuperarlo

```
c.init(Cipher.DECRYPT_MODE, sKey);
try {
      String s = (String)so.getObject(c);
   } catch (Exception e) { // hacer lo que corresponda
};
```

- **Para pruebas online**
  - http://www.tools4noobs.com/online_tools/encrypt/
  - http://www.tools4noobs.com/online_tools/decrypt/

- Otros algoritmos de cifrado simétrico
  - **Camellia:** Cifrador de bloques de 128-bit y 256 bit desarrollado conjuntamente por Mitsubishi y NTT de Japón. Aprobado su uso por ISO/IEC, el proyecto NESSIE de la Unión Europea y el Japanese CRYPTREC project. Niveles de seguridad comparables a AES. **(RFC: 3713)**
  - **Cifradores cuánticos**, su potencia descansa en la mecánica cuántica (a diferencia de los anteriores en la complejidad computacional) a partir del principio de incertidumbre de Heinsenberg.
    - Dos protocolos de intercambio de clave secreta: BB84 y Fotones Entrelazados E91

- **Criptoanálisis:** proceso de intentar averiguar el texto plano o la clave
- Dos enfoques:
  - **Fuerza bruta**
    - Intentar todas las claves posibles
  - **Explotar las debilidades del algoritmo de cifrado o de la clave**